

Privacy and personal-data map

This map follows data from collection through storage, recipients and deletion. "No mechanism" is a finding, not an assumption of deletion.

Data element	Collection	Storage/recipients	Access/security	Retention	Deletion/export	Disclosure status
Name/email/phone/profile/avatar/language	Firebase signup, OTP, profile	Firebase + Postgres; email/SMS vendors	Bearer auth; RDS encryption	Indefinite	No account workflow	No privacy notice
Password/session/token	Firebase/email-password; mobile persistence	Firebase; AsyncStorage	Firebase token verification; Android backup risk	Provider-defined/unknown	No coordinated delete	Undisclosed
Aadhaar/PAN/licence/passport/voter ID and images	KYC	Postgres metadata + private S3 verification; possible admin access	S3 encryption/block-public; mock approval	S3 365-day lifecycle; DB/object versions not coordinated	No erase/export	UI assurance exceeds evidence
Caste/community allow-list and affirmation	Host listing, guest booking/assistant	Listing/booking notes, invoice/email/AI prompt	Access review incomplete	Indefinite	No deletion	No valid purpose/notice
Address/lat-lng/date/s/guest count	Search/checkout/safety	Postgres, Google Maps, responders	RDS encrypted; role checks	Indefinite	No selective deletion	Undisclosed
Payment/refund/payment details	Checkout/provider payouts	Razorpay + Postgres payments, payout_accounts	Webhook HMAC; RDS encrypted	No stated schedule	No user export/deletion policy	No payment privacy terms
Chat/voice/media	Messaging/assistant/voice	Postgres + S3 chat; Vertex/Gemini/TTS	Authz/WS gaps; S3 private	No expiry	No deletion orchestration	Undisclosed processor use
Reviews/listings/photos	Provider onboarding/review	Postgres + S3 + CDN	Public/private controls; moderation opt-in	Listing lifetime	No user-controlled removal policy	Takedown process absent
Device IDs/IP/user agent/FCM token	Analytics, push, consent, fraud	DynamoDB/Postgres/FCM/Mixpanel adapter	Some TTL/cleanup; mobile logs	Raw/rollup periods vary	No unlink/export workflow	No cookie/device notice
Search/AI prompts/memory/preferences	Search/assistant	DynamoDB/DB/Vertex	Prompt and memory boundaries unclear	No clear reset/delete	No user control	Undisclosed AI processing
Notifications/email/SMS logs	Booking/system messages	DB/Dynamo/SES/SNS/FCM/SMTP	Vendor controls not evidenced	Mixed	No deletion workflow	Undisclosed recipients

Required deletion orchestration

An account deletion request must be authenticated/re-authenticated, idempotent and auditable without retaining the original content. It must coordinate Firebase user, Postgres profile/listings/messages/analytics identifiers, S3 objects/versions, DynamoDB events and device links, FCM tokens, vendor deletion/retention requests, and financial records retained for statutory reasons. It must expose status, exceptions and appeal/support. No such workflow exists in `users.routes.ts`.

Privacy findings

ID	Domain	Title	Severity	Confidence	Evidence	User/business impact	Recommended correction	Effort	Owner	Release blocker	Status
PRIV-001	Notice	No functional privacy/terms document	High	Confirmed	Footer #, no routes	No informed processing decision	Versioned notice + consent references	Medium	Legal/Privacy	yes	Open
PRIV-002	Rights	No account deletion/export	High	Confirmed	users API only profile/marketing	Rights and app-store failure	DSAR/export/erase orchestrator	High	Backend/Privacy	yes	Open

ID	Domain	Title	Severity	Confidence	Evidence	User/business impact	Recommended correction	Effort	Owner	Release blocker	Status
PRIV-003	Sensitive data	Caste and KYC data over-collected/persisted	Critical	Confirmed	listing/booking/verification flows	Discrimination and identity harm	Disable/minimise; retention/access controls	High	Product/Legal	yes	Open
PRIV-004	Retention	Logs and data retention are inconsistent/undocumented	High	Confirmed	CDK 7/30/90-day logs; CERT-In 180	Compliance and incident evidence gap	Data inventory, retention schedule, India log store	Medium	CISO/Privacy	yes	Open
PRIV-005	Processors	Firebase/Google/Vertex/analytics recipients not disclosed	Medium	High confidence	provider/config inventory	Cross-border transparency/contract risk	Processor register and notice updates	Medium	Legal/Procurement	before real PII	Open